JWT (JSON Web Token) — A Simple Guide

What it is and how it works

1. What is a JWT?

A JWT is a small, signed piece of text that the server gives the user after a successful login. The user sends it back with every request to prove who they are. Think of it like a **wristband at an event**: you show your ID once at the gate, get a wristband, and after that the staff only check the wristband.

Because all the needed info is **inside the token** and it is protected by a signature, the server does not need to store sessions. This is called **stateless authentication**, which is why JWT is popular for REST APIs and mobile apps.

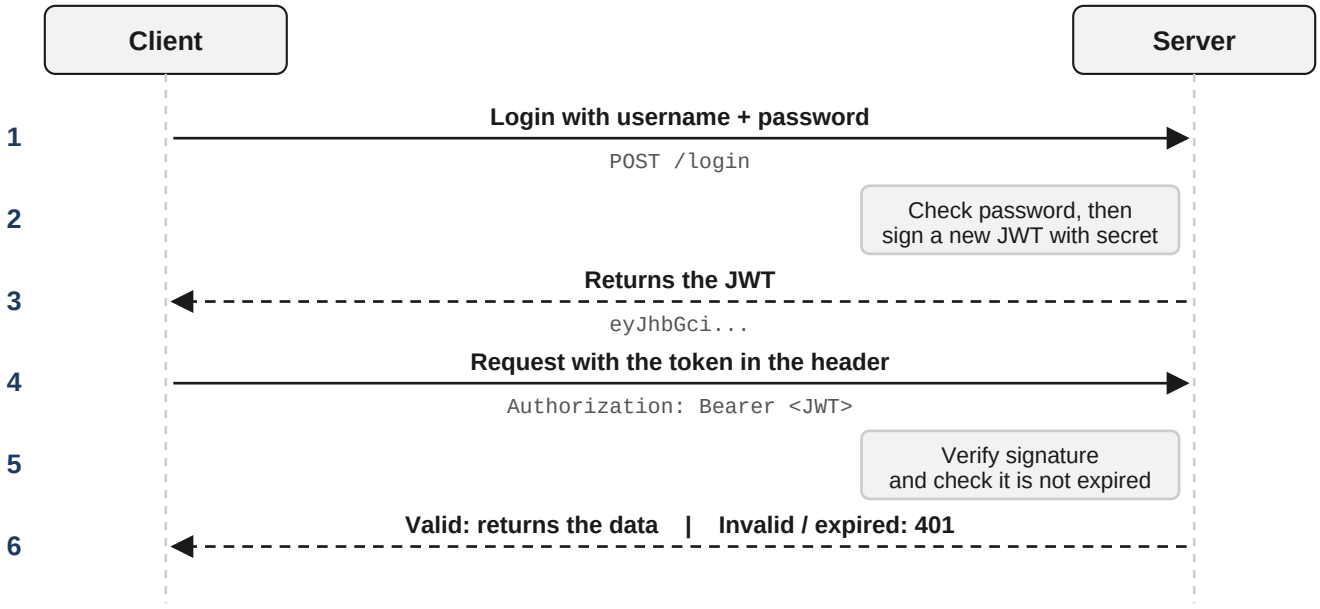
2. The structure: three parts separated by dots

`xxxxx.yyyyy.zzzzz` → `Header . Payload . Signature`

Part	What it contains	Example (decoded)
Header	The token type and the signing algorithm.	`{"alg": "HS256", "typ": "JWT"}`
Payload	The **claims**: data about the user, e.g. username (sub), role, issued-at (iat) and expiry (exp).	`{"sub": "ahmed", "role": "USER", "exp": 1760198400}`
Signature	Made from header + payload using a **secret key only the server knows**. Any change to the token breaks it.	`HMACSHA256(header + "." + payload, secret)`

Important: the header and payload are only Base64-encoded, **not encrypted**. Anyone can read them. The signature stops people from *changing* them, not from *reading* them, so never put passwords or private data in a JWT.

3. How it works



The server never saves the token. On every request it just re-checks the signature with its secret key, so steps 4 to 6 repeat until the token expires and the user logs in again.

4. Pros, cons and good practice

- **Pros:** no session storage on the server, scales easily, works well with mobile apps and microservices.
- **Cons:** a token cannot easily be cancelled before it expires (logout is done on the client, or with a blacklist).
- Keep tokens **short-lived** (15 min to 24 h), and use a refresh token for longer sessions.
- Use a **strong secret key** kept in config or environment variables, never in Git. Always use HTTPS.